

Prioritized Remediation Roadmap

LearnSphere EdTech — NIST Cybersecurity Framework (CSF) 2.0 Gap Assessment

Document ID	LS-NIST-002
Version	1.0
Assessment Date	07-Sep-2026
Assessment Basis	Step 05 — Gap Calculation and Prioritization Inputs
Scope	LearnSphere EdTech cloud-hosted LMS, student/teacher data, IAM, application, database, endpoints, monitoring and relevant third parties

Company / Entity	LearnSphere EdTech
Standard Reference	NIST Cybersecurity Framework (CSF) 2.0; NIST Quick-Start Guide: Creating and Using Organizational Profiles
Related Documents	Project 1 - LearnSphere EdTech ISMS (ISO/IEC 27001:2022 implementation documentation set: ISMS scope, asset register, risk register, Statement of
Document Owner	Chief Information Security Officer (CISO)
Classification	Confidential · Internal Use Only
Version	1.0 · Final
Prepared By	Mr. Meejan Shaikh, GRC Analyst, Information Security Management Team
Reviewed By	Information Security Manager
Approved By	Chief Information Security Officer (CISO)
Assigned Date	10 August 2026
Assessment Date	07 September 2026
Issue Date	10 September 2026

Management Objective

Prioritize the most material NIST CSF 2.0 gaps so that remediation effort is directed first toward risks affecting children's data, student-record access, privacy obligations, and high-value security outcomes. The roadmap deliberately sequences foundational governance and inventory work before broader optimization activities.

Priority principle: address the highest risk-reduction opportunities first, while recognizing regulatory exposure, implementation effort, and dependencies.

1. Prioritization Methodology

A simple weighted model was applied to the largest Step 05 gaps. Each factor is scored on a 1–5 scale, with a higher score representing greater urgency or value. The weighted score is used to rank remediation work; it is a project prioritization method and is not an official NIST CSF maturity or scoring scale.

Factor	Weight	How it is considered
Regulatory / contractual exposure	30%	Impact of privacy, children's-data, customer, legal or contractual obligations if the gap remains open.
Risk-reduction impact	35%	Expected reduction in likelihood or impact of unauthorized access, disclosure, disruption or loss.
Cost / effort	15%	Implementation complexity, resource demand, technology effort and organizational change.
Dependency / enablement	20%	Extent to which closing the gap enables other controls, processes or later roadmap activities.

Scoring interpretation

Weighted priority score = Regulatory/Contractual × 30% + Risk Reduction × 35% + Cost/Effort × 15% + Dependency/Enablement × 20%. Scores are rounded to two decimals. Where two gaps have comparable scores, the one with greater children's-data exposure or stronger dependency value is sequenced first.

2. Top 6 Priority Gaps

NIST Outcome	Function	Current→Target	Gap	Priority	Score	Current-State Finding	Primary Remediation	Owner
PR.AA-05	Protect	2→4	2	Critical	4.70	Student-record access permissions, privileged entitlements and authorization reviews are not consistently governed with evidence-based least privilege and separation of duties.	Formal RBAC; least-privilege baseline; SoD rules; quarterly access certification; privileged-account register; JML integration; exception tracking and metrics.	Information Security Manager / IAM Owner
GV.OC-03	Govern	1→3	2	High	4.70	Legal, privacy, contractual and children's-data requirements are not consistently translated into operational requirements.	Create a children's-data requirements register covering privacy, parental consent, purpose limitation, retention, contractual obligations and accountable owners.	GRC / Privacy / Legal
ID.AM-07	Identify	1→3	2	High	4.70	The authoritative inventory and metadata for designated/sensitive student data are incomplete.	Build an authoritative data inventory with data type, purpose, owner, location, sensitivity, flow and retention attributes.	Data Governance / IT
PR.DS-10	Protect	1→3	2	High	4.50	Retention and disposal of student data are not consistently enforced across systems and repositories.	Define retention schedules, implement deletion mechanisms, manage exceptions and perform evidence-based disposal verification.	Data Governance / Application Owners
DE.AE-04	Detect	1→3	2	High	4.05	Correlation between IAM events, application activity and student-record access is not consistently defined.	Implement SIEM correlation/use cases for anomalous student-record access, privileged activity and identity/application events.	SOC / Security Engineering
RC.IM-01	Recover	1→3	2	Medium	3.25	Lessons learned are not systematically converted into tracked, owned and verified improvements.	Establish post-incident and post-exercise improvement workflow with action owners, due dates, evidence and closure verification.	Information Security Manager / GRC

3. Phased Remediation Roadmap

0–3 MONTHS Establish the control foundation and reduce the most immediate exposure.				
Priority / Gap	Workstream	Key Deliverables	Priority	Owner
GAP-09	Student-record access governance	Approve RBAC and least-privilege model; identify privileged roles; perform emergency access review; launch quarterly certification; integrate JML and exceptions.	Critical	Information Security / IAM

DOCUMENT ID: LS-NIST-002 | VERSION: 1.0

INTERNAL · CONFIDENTIAL

Priority / Gap	Workstream	Key Deliverables	Priority	Owner
GAP-01	Children's-data governance	Create requirements register; document parental-consent requirements, purpose limitation, retention expectations, contractual obligations and accountable owners.	High	GRC / Privacy / Legal
GAP-06	Student-data inventory	Start authoritative inventory; identify designated/sensitive student-data sets, owners, locations, flows and metadata gaps.	High	Data Governance / IT
GAP-12	Retention & disposal	Define retention schedule and exception process; identify systems requiring deletion controls; begin disposal verification.	High	Data Governance / Application Owners
GAP-16	Detection correlation	Define priority SIEM use cases for IAM + application + student-record access; identify logging gaps and required telemetry.	High	SOC / Security Engineering

3–6 MONTHS Operationalize, measure and integrate the new controls into normal business processes.				
Priority / Gap	Workstream	Key Deliverables	Priority	Owner
GAP-09	Access certification & metrics	Complete first formal quarterly certification; measure review completion, excessive access, privileged exceptions and remediation aging.	Critical	Information Security / IAM
GAP-01	Privacy-by-design workflow	Embed children's-data requirements into product/change intake, data-processing reviews and security/privacy risk assessments.	High	GRC / Product / Privacy
GAP-06	Inventory completion	Complete data inventory and map major application/database flows to data types, owners, purpose and retention requirements.	High	Data Governance / IT
GAP-12	Deletion enforcement	Implement or validate deletion jobs and evidence; establish exception register and sample-based disposal verification.	High	Application / Data Owners
GAP-16	Monitoring & alert metrics	Deploy correlation rules; establish MTBD/MTTI and investigation-quality metrics; perform tuning based on observed alerts.	High	SOC / Security Engineering
GAP-24	Improvement tracking	Formalize post-incident/post-exercise review and convert lessons learned into owned, dated, evidence-backed actions.	Medium	GRC / Information Security

6–12 MONTHS Test effectiveness, close residual gaps and reassess the target state.				
Priority / Gap	Workstream	Key Deliverables	Priority	Owner
Cross-functional	Control effectiveness	Run access recertification cycles, privacy/data reviews and monitoring effectiveness checks; verify evidence quality and exceptions.	High	Information Security Manager
Cross-functional	Recovery & resilience	Conduct scenario-based recovery exercises involving database compromise, ransomware and student-data loss; validate RTO/RPO dependencies.	Medium	IT / Business Continuity
Cross-functional	Third-party oversight	Strengthen monitoring expectations and assurance evidence for relevant cloud, payment and other critical service providers.	Medium-High	Vendor Management / GRC
Cross-functional	Target Profile reassessment	Re-score the 24 selected outcomes, compare Current vs Target Profile results, and reprioritize remaining gaps based on measured performance.	High	GRC / Information Security Manager

4. Dependencies and Implementation Controls

Dependency	Why it matters	Required control
Children's-data requirements	Access, retention and processing decisions must reflect documented privacy/consent obligations.	Approved requirements register and accountable owner.
Data inventory	Access and disposal controls cannot be reliably applied without knowing where designated data resides.	Authoritative inventory with ownership and metadata.
IAM / JML	Access governance depends on timely joiner, mover and leaver changes.	JML workflow, SLA, exception handling and evidence.
Logging coverage	Correlation and detection depend on complete identity, application and data-access telemetry.	Critical-source coverage baseline and SIEM use cases.

5. Management KPIs

KPI	Target / Direction	Review Cadence
Student-record access certification	100% of in-scope access reviewed each quarter; exceptions aged and tracked.	Quarterly
Privileged-access exceptions	Zero unauthorized standing privileged access; all exceptions documented and approved.	Monthly
Student-data inventory coverage	100% of designated data stores and major processing flows mapped.	Monthly until complete
Retention/disposal verification	Evidence available for scheduled deletion and approved exceptions.	Quarterly
Security monitoring coverage	Critical IAM/application/data-access telemetry covered by approved use cases.	Monthly
Incident detection metrics	MTTD/MTTI tracked with trend review and corrective action for deterioration.	Monthly
Improvement action closure	Actions have owner, due date, evidence and effectiveness verification.	Monthly

6. Closing Recommendation

Management should approve the roadmap as the prioritized remediation baseline for the next 12 months. The immediate objective is not to maximize the number of controls completed, but to reduce the most material exposure: unauthorized access to student records, weak governance of children's-data requirements, incomplete visibility of sensitive data, inconsistent retention/disposal, and insufficient correlation of security events.

The 0–3 month phase establishes ownership, requirements, inventory and access-control foundations. The 3–6 month phase converts these foundations into repeatable operating processes and measurable controls. The 6–12 month phase validates effectiveness through testing, resilience exercises and a formal reassessment of the NIST CSF 2.0 Current and Target Profiles.

7. Approval and Governance

Role	Name	Signature	Date
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	07-Sep-2026
Reviewed By	Information Security Manager	_____	07-Sep-2026
Approved By	CISO	_____	07-Sep-2026

Document basis: NIST CSF 2.0 assessment work completed in Steps 01–05, including the 24 selected outcomes, internal 0–4 maturity scale, target maturity decisions and sorted gap calculation.